Aretia Finance — Vulnerability Status After Remediation

Version	1.0, 20 October 2026
Original review	`REPORT.md` in this folder (commit `5e7fb23`, 18 October 2026)
Remediated code	branch `claude/eloquent-turing-97mg6r`, commit `b6fb32c` (20 commits after `73386ef`; 276 files)
Prepared by	Claude Code (AI-assisted remediation and re-audit), at the request of the Aretia Finance owner

> **Read this first.** This is an AI-assisted remediation and fix review, laid out like a professional audit's remediation report. It was **not** produced by ChainSecurity or by any audit firm, and it gives no guarantee that the code is free of vulnerabilities.
>
> **Nothing in it is live yet.** The fixes are on the branch above. They take effect only once the branch is merged and deployed, and the contracts and programs are deployed or upgraded, as set out in section 6.

---

1. Summary

How the work was done:

- **Fixing:** six engineers worked in parallel, each in an isolated copy of the repository, one per area: swap engine, cross-chain and transaction builders, server and database, markets and Launch Box, Solana programs, EVM contracts.
- **Re-audit:** four fresh reviewers, who had not written the fixes, reviewed them and actively tried to bypass each one, writing their own attack tests.
- **Second round:** every material problem the re-audit raised was fixed, and the re-checked.

Results:

- **High findings:** all 3 are resolved. The re-audit wrote 33 dedicated bypass tests against them, and none got a malicious 0x transaction, an injected Jupiter instruction or a forged recovery record through to signing.
- **No new High or Medium issues** were introduced by the fixes.
- **The deployed EVM contracts** (`AretiaCurve.sol`, `AretiaTokenFactory.sol` on Ethereum, BNB Chain and Polygon) are immutable and were left byte-for-byte unchanged. Their findings are mitigated around them: a rescue contract, a pair seeder, warnings on the page, and fee-key monitoring.

Severity	Findings	Resolved	Mitigated	Partly resolved	Acknowledged (accepted / immutable)
High	3	3	—	—	—
Medium	12	9	3	—	—
Low	31	23	1	5	2
Informational	27	15	—	4	8
Total	**73**	**50**	**4**	**9**	**10**

Status definitions:

- **Resolved:** the root cause is removed in code.
- **Mitigated:** the code that holds the risk cannot change, so the risk is reduced around it.
- **Partly resolved:** the main exploit is closed but a stated residual remains.
- **Acknowledged:** accepted by design, or impossible to change in deployed immutable code; documented.

Evidence:

- **Website:** `npm run lint` clean; `npm run typecheck` 0 errors; 2,477 vitest tests pass (up from 2,250 at the original review); `npm run build` succeeds.
- **The original proofs of concept** (`poc/`): all 13 that demonstrate an exploit now **fail**, meaning the exploit is blocked. Of the two that still pass, one only prints output and asserts nothing; the other (a permanent-delegate rating) now passes for a correct reason, because its test token holds no delegate.
- **Solana LiteSVM suites:**
  - aretia-pool 29/29, aretia-curve 19/19, aretia-curve-grad 18/18, act-staking 5/5;
  - 6 Meteora-dependent curve tests skip here, because the Meteora binary could not be fetched;
  - every program rebuilds byte-for-byte to its committed binary with Agave 2.1.21.
- **EVM:** `contracts-evm/test` passes 32/32, plus a 750-step random stress test of `AretiaPool` accounting run by the re-auditor. All artifacts recompile byte-identical with solc 0.8.26.

---

2. Status of every finding

2.1 High

ID	Finding	Status	What was done	Evidence
H-1	0x AllowanceHolder `exec` not checked	**Resolved**	`exec` is decoded strictly: operator == target, and the target must be the current or previous 0x Settler, read from 0x's on-chain registry (`0x0000…4533…cEae`, feature 2) through Aretia's own node. A failed read refuses the route. The Settler `execute` call must pay the taker, in the requested token, with a minimum equal to the quote's and at least the user's slippage floor. Every other selector (e.g. `executeMetaTxn`) is refused. Native value must equal the input, and the simulation measures the buy-token change.	`chains/evm.test.ts` "H-1" (8 tests); re-audit bypass suite; original PoC now fails
H-2	Jupiter instructions not allow-listed	**Resolved**	`vetSwapInstructions` lets through only ComputeBudget (priority fee capped), System transfer/createAccount in safe forms, ATA create, SPL/Token-2022 SyncNative / CloseAccount-to-user / wSOL init and transfer, one Jupiter v6 instruction, and Aretia's own fee instructions. Approve, SetAuthority, Assign, nonce operations, extension instructions and unknown programs are refused. As a second layer, every writable account (up to 100) is watched: no user token account may change owner, delegate or close authority or lose balance, and the wallet must stay System-owned.	`walletSwap.test.ts` (10); re-audit bypass suite (25 cases); original PoC now fails
H-3	Forged "Move USDC" recovery record	**Resolved**	See the H-3 detail below the table.	`cctp.forged.test.ts` (17); `_swingsRecords.test.ts`; original PoC now fails

H-3 detail, by layer:

- **Client, signing:** the client signs only quotes made on the current page. A restored or saved quote is retired and must be quoted again, which re-runs the safety assessment and the canary access list.
- **Client, builder:** USDC, TokenMessenger and domains come from built-in constants. The amount cap and a maximum fee are applied again.
- **Client, inspector:** a CCTP inspector decodes every `approve`, `depositForBurn` (EVM and Solana) and claim argument. The claim's attested message must mint to this move's recipient on its destination.
- **Client, parties:** the sender must be the connected wallet. Any other recipient requires explicit full-address confirmation.
- **Client, network:** every EVM step is bound to its network ID.
- **Server:** records need an HMAC write token to be changed.

2.2 Medium

ID	Finding	Status	What was done	Evidence
M-1	Referral credit multiplied by changing hash case	**Resolved**	EVM hashes are canonical lower case and anything else is refused. Migration `0013` merges existing duplicates and adds a lower-case constraint. Payouts group by the canonical hash.	`_swingsReferrals.test.ts` "M-1"; migration tested twice on Postgres
M-2	Fee recipient can freeze trading (EIP-7702)	**Mitigated** (curve, immutable) / **Resolved** (pool)	See the M-2 detail below the table.	`contracts-evm/test/pool.test.mjs` PoC 2; `feeKeyMonitor.test.ts`
M-3	Supply held outside a curve can drain buyers and lock their sells	**Mitigated**	The EVM and Solana trade cards show the share of supply outside the curve, the opener's live balance, and a strong warning when it is above 0. The programs themselves were not changed: the EVM curve is immutable, and the Solana curve keeps its design.	`walletCurveEvmRescue.test.ts`, `walletCurveCore.test.ts` "M-3"
M-4	Graduation and the V2 pool page blocked with 1 wei	**Mitigated**	See the M-4 detail below the table.	`rescue.test.mjs` (12), `seeder.test.mjs` (9)
M-5	"Burned" Solana pool position could be reclaimed	**Resolved**	A position counts as new only when the account is genuinely fresh. `transfer_position` refuses the zero key, the System program and the pool, and settled fees are never lost.	LiteSVM `m5_*` (fail on the old build)
M-6	Dangerous Token-2022 mints listed and shown safe	**Resolved**	See the M-6 detail below the table.	`token2022.test.ts`, `indexer.test.ts`, `tokenPageCore.test.ts`
M-7	"Verified" checker misnumbered extensions, passed proxies	**Resolved**	Corrected enum and an allow-list (18–23 pass; 10 is flagged; everything else fails). The extensions are listed in the report. EIP-1167, EIP-1967, EIP-7702 (`0xef0100`) and any DELEGATECALL (a walk over the bytecode that skips PUSH data) are detected. Supply is read at two blocks.	`verifyToken.test.ts` "M-7"
M-8	Fake pools take over the displayed price and market cap	**Resolved**	"Major" quote tokens are matched by **address**. A major-paired pool with at least $1,000 always sets the price, whatever a pool against a made-up token claims. With no such pool, the deepest is shown, labelled with its quote, without liquidity or market cap, and marked thin.	`markets.test.ts`, `walletHoldings.test.ts`; original PoC fails

ID	Finding	Status	What was done	Evidence
M-9	EVM Aretia Pool: unlocked pools could be emptied	**Resolved** (needs redeploy)	`createPool` requires locking the initial liquidity. `pool.locked` is tracked and never falls, and the card shows "x% of liquidity locked".	`pool.test.mjs` PoC 3
M-10	`act-staking` initialisation front-run or blocked	**Resolved** (fresh deploy)	`initialize_config` must be signed by the program's upgrade authority. ProgramData is validated: owner is the upgradeable loader, and the address matches the program. The mint must be ACT. The vault uses `init_if_needed`.	LiteSVM `m10_*` (3, fail on the old build)
M-11	Alerts could be stopped for everyone; outbound requests to any host	**Resolved**	Push endpoints are only accepted on push-service hosts; userinfo, port, trailing-dot and suffix tricks are refused, and redirects are not followed. Channels are read in ordered pages, price lookups are shared fairly between owners, and favourites per owner and test sends are capped.	`vapid.test.ts`, `_swingsNotify.test.ts` "M-11" (6)
M-12	Pressing Swap could sign a re-quote the user never saw	**Resolved**	`refreshDrift`: a change of provider, or of output or minimum by more than 0.3%, stops the swap and asks for fresh confirmation.	`router.test.ts` "M-12"

M-2 detail:

- **AretiaPool:** the protocol fee is accrued in `protocolOwed`, counted in solvency, and paid out by anyone through `withdrawProtocolFees()`. Trades never send to the fee address.
- **Deployed curve:**
  - an hourly GitHub monitor (`fee-key-monitor`) opens a `security` issue and fails if any code, such as an EIP-7702 delegation, appears on the fee address on any of the three chains;
  - the EVM deploy verifier refuses a fee address with code;
  - the operating rules are documented: keep the key cold, never sign a 7702 authorisation.

M-4 detail:

- `AretiaCurveRescue.sol`**:** permissionless and holds nothing between calls. It repairs a dust-poisoned pair and calls `graduate` in one transaction. It was tested against all three blocking tricks, against random poisoned pairs, and against attempts to steal or graduate at a bad price.
- `AretiaPairSeeder.sol`**:** does the same for the Uniswap V2 launch page.
- **Website:** both are offered, each with a strict inspector, and the page checks the helper's code and configuration first.
- **Deployment:** both still need deploying (section 6).

M-6 detail:

- **Launch Box indexer:** applies the exact on-chain mint rule. It is a byte-level port of `check_mint`, and a differential fuzz of 200,000 random mints found no disagreement.

- **Pending launches:** stored but hidden until finished.
- **Re-checks:** every listed Solana token is re-checked, and is hidden only after two failing reads in a row.
- **Token page and risk engine:** read each extension and its authority field. Permanent delegate, transfer hook, pausable and non-transferable are "Restricted" while a live authority holds them.

2.3 Low

ID	Finding	Status	Note
L-1	EVM transactions not bound to `chainId`	**Resolved**	Every EVM send path carries and inspects `chainId`: swap, launch, curve, rescue, Aretia Pool, V2 pool and seeder, send, Shield revoke, CCTP. Network and account are re-read before each send.
L-2	Separate EVM fee could be lost or charged twice	**Mitigated**	The swap is simulated again after the fee confirms. A "fee paid" record (10 minutes) is cleared only once the swap **confirms**, and a warning is shown. Residual: without a batching wallet, the fee is still its own non-refundable transaction.
L-3	Sign-in replay; domain from `Origin`	**Resolved**	EIP-4361 and Sign In With Solana messages; server-issued single-use nonces (atomic, tested for races); domain from configuration; session versions with "sign out everywhere". Residual: wallets that do not check the domain in a signed message.
L-4	Ramp signed MoonPay links for any wallet	**Partly resolved**	Links need a session and are signed only for the signed-in wallet, and each is logged. Residual: an attacker can still get a link for their own wallet.
L-5	Referral caps read an unordered page; rows unbounded	**Resolved**	Ordered, filtered queries; a daily row limit; per-owner and per-IP limits (in memory per instance).
L-6	Referral payments not final	**Partly resolved**	Solana `finalized`, per-chain EVM depth, and the payout export re-checks every payment. Residual: public nodes, no keyed EVM RPC.
L-7	Self-referral and backdated binding	**Partly resolved**	A server-signed capture is required, and transactions before the binding are refused (backdating closed). Residual: a trader can still name their own second wallet, worth at most 20% of their own fee.
L-8	Solana curve accepted a sale paying 0	**Resolved**	Refused in both curves' maths, in the program and in the page.
L-9	Fee-claim screen could be jammed	**Resolved**	The position is found from Meteora's own accounts by pool.
L-10	EVM curve graduation and abort liveness	**Acknowledged** (immutable)	Documented, with recommendations for any future version.
L-11	EVM curve precision at tiny totals	**Acknowledged** (immutable)	Documented.

ID	Finding	Status	Note
L-12	EVM graduate page had no recovery path	**Resolved**	The revert is explained and "Graduate anyway" is offered through the rescue helper.
L-13	Aggregators fail open	**Resolved**	Off unless the server says on.
L-14	Rate limit keyed on a spoofable IP	**Partly resolved**	Every endpoint uses `clientIp()`. Residual: limits are per instance (no shared store).
L-15	Look-alike and impersonating names	**Resolved**	NFKC plus a confusables skeleton (fullwidth, mathematical, small capitals, hooked letters, ₮, Cyrillic), reserved names, invisible characters stripped. The "Not the real one" chip appears in Launch Box, Markets, search, the swap picker and the token page.
L-16	Market-only data could show green	**Resolved**	Market-only readings are never green. Tokens whose issuer holds powers show yellow "Established, issuer controls", the same on every surface including registry rows.
L-17	CSP not enforced; CDN script without SRI	**Partly resolved**	`@solana/web3.js` from jsDelivr is pinned with a sha384 on every page, and a test enforces SRI for all external scripts. Residual: Jupiter's unversioned widget cannot be pinned, and `script-src` is still report-only.
L-18	Deploy verifiers could be fooled	**Resolved**	Genesis hash checked per cluster; the EVM verifier reads back the factory's fee settings and refuses a fee address with code.
L-19	EVM pool dust positions block transfers	**Resolved** (needs redeploy)	Positions merge on transfer, empty ones are deleted, and "Your pools" filters before capping.
L-20	EVM pool calls had no deadline	**Resolved** (needs redeploy)	A deadline on every trade and liquidity call; the inspector requires it to be within one hour.
L-21	Closing the fee wSOL account halted Solana pool swaps	**Resolved**	Created idempotently inside the swap from four optional trailing accounts, each checked by exact address.
L-22	JIT liquidity during the launch-fee window	**Resolved**	Adding liquidity is refused while the launch fee is above its base.
L-23	A fully emptied pool was dead for good	**Resolved**	Liquidity never falls below a permanent minimum.
L-24	EVM Send skipped the address-poisoning guard	**Resolved**	Same guard and acknowledgement as Solana Send.
L-25	Meteora pool inspector trusted the SDK	**Resolved**	Price, implied amount and pool address are computed independently.
L-26	Shield missed some approval spenders	**Resolved**	AllowanceHolder, Curve, Balancer and Permit2-internal allowances, with revoke through Permit2.
L-27	Tracked-pools flood; costly pool scans	**Resolved**	Only known pools are tracked; mint existence is checked first; global budget; provider error text no longer exposed.
L-28	Alert worker open redirect	**Resolved**	Same-origin URL check.

ID	Finding	Status	Note
L-29	Spam tokens shown with large values	**Resolved**	No value under $1,000 of liquidity; thin prices are marked and left out of the portfolio total.
L-30	act-staking tier never decays	**Resolved**	The effective tier is computed on read, and expired locks count at 1.0×.
L-31	curve-grad hard-coded the devnet pool	**Resolved**	A `mainnet` cargo feature fails to build until a pool id is set.

L-5, L-14 and L-27 depend on in-memory limits per server instance; a shared store (for example Upstash) would make them exact.

2.4 Informational

ID	Status	Note
I-1, I-2	**Resolved** (docs)	README, VERIFY (curve verification added) and BONDING_CURVE_EVM corrected. The verified source comments cannot change and are listed as out of date.
I-3	**Resolved** (pool) / **Acknowledged** (curve)	Pool events corrected.
I-4, I-6, I-9, I-10	**Acknowledged**	Immutable or by design; documented.
I-5	**Partly resolved**	The pool carries its fee rounding remainder. A few wei are still stranded after everyone exits.
I-7	**Resolved**	—
I-8	**Acknowledged**	EVM JIT liquidity; inherent to the design.
I-11	**Resolved**	Migrate requires leftovers to be at least the starting balances.
I-12	**Acknowledged**	Documented.
I-13	**Resolved**	The rent floor is the rent the vault actually paid; a rise in rent cannot freeze sells.
I-14	**Acknowledged**	Events are still logs, not `emit_cpi!`.
I-15, I-16	**Resolved**	—
I-17	**Acknowledged**	Browser-clock quotes; adapter cosmetics.
I-18	**Resolved**	Documentation drift fixed; duplicate durations and huge multipliers refused.
I-19, I-20, I-21, I-23, I-24, I-27	**Resolved**	—
I-22	**Partly resolved**	Constant-time comparisons and a header-based inbox secret. The `?s=` fallback and the session-secret fallback remain until `SWINGS_SESSION_SECRET` is set.
I-25	**Partly resolved**	Automatic pruning (unfinished transfers are kept). Response caches unchanged.

ID	Status	Note
I-26	**Partly resolved**	Verified badge, stale names, padlock, Telegram symbols, Send re-plan and the u64 range check are fixed; there is a TradingView hash hook. Unchanged: main-thread factory nonce search, local-clock abort timing, one-receipt finality.

---

3. Issues raised by the re-audit and how each was closed

The re-audit looked for new problems introduced by the fixes. None was above Low.

Raised	Severity	Status
Code deployed before migration 0014 breaks every signed-in feature	Low–Medium	**Closed by procedure.** The operator steps now apply 0014 first. It is additive and safe with the current code.
Rotating the session secret lost referrals for good	Low	**Fixed.** A refused capture is answered `bad-capture`, and the browser fetches a new one.
Pruning deleted unfinished cross-chain recovery copies	Low	**Fixed.** Only finished moves are pruned.
`SWINGS_LOGIN_DOMAINS` written with `https://` broke sign-in	Info	**Fixed.** The scheme is stripped.
Migration 0013 deletes duplicate rows	Low	**Closed by procedure.** Back up and review first (section 6).
CCTP transactions not bound to `chainId`	Low	**Fixed.**
Fee record cleared on send rather than on confirmation	Low	**Fixed.**
CCTP claim did not check the message's recipient	Info	**Fixed.**
Restored record's source domain not validated	Info	**Fixed.** Taken from Circle's table.
Pending Launch Box mints listed for up to a day	Low–Medium	**Fixed.** Hidden until finished.
One RPC answer could permanently delete a listing	Low	**Fixed.** Soft hide after two failing reads; re-admitted when it passes.
Re-check covered only the newest 1,000 rows	Low	**Fixed.** Pages through all rows, pending first, with its own budget.
Registry rows still showed green for issuer-controlled tokens	Low	**Fixed.**
Extension rules gave false positives (a given-up authority was still "Restricted")	Info	**Fixed.** Authority fields are read; ACT reads as an accurate warning.
Fee-key monitor alerts were weak	Low	**Fixed.** It opens an issue, fails after 3 unreadable runs, keeps RPC URLs secret and redacts them.
Web seeder flow did not verify the seeder	Info	**Fixed.** Code and `router()` are checked before approving.

Raised	Severity	Status
act-staking had no committed artifact	Info	**Fixed.** Artifact and sha-256 committed.
Seeder can still be blocked when someone owns liquidity in the pair	Low	**Open.** Only reachable if tokens are distributed before the pool is opened; the page explains it.
Fee key could charge a hidden rent on each Solana pool trade	Info	**Open, operational.** It requires the trusted fee key to repeatedly close its own account; covered by the fee-key rules.
Older recovery records can no longer be updated on the server	Low	**Accepted.** Moves in flight at deploy time keep working locally; only their server copy stops updating.
0x native-sell form assumed	Info	**To verify** with one live small ETH, BNB or POL sale after deploy. A different form fails closed (no route), never unsafe.

---

4. Residual risks

1. **The deployed EVM curve's fee key is a freeze key.** Under EIP-7702 its holder can stop all trading on every curve. Monitoring and operating rules reduce the risk; only a new contract version removes it.
2. **Creators can hold supply outside a curve and sell it in** (M-3). Buyers are now warned clearly, but the contracts still allow it.
3. **In-memory rate limits** are per server instance (L-5, L-14, L-27).
4. **Self-referral through a second wallet** is still possible, worth at most 20% of one's own fee (L-7).
5. **Public RPC nodes are trusted** for simulations, finality and registry reads. A lying node can still mislead the checks; keyed providers reduce this.
6. `script-src` **is not enforced**, and Jupiter's widget scripts cannot be pinned (L-17).
7. **No independent audit.** Every program and contract that holds funds should still be audited by an independent firm before significant value is deployed: `aretia-curve`, `aretia-pool`, `act-staking`, `AretiaPool.sol`, and the two new EVM helpers.

---

5. New or changed code that holds funds

Artifact	sha-256	Status
`program/aretia-curve/artifacts/aretia_curve.so`	`0275bb1f7a1844b8d1a993d501538947866cd0ee928283f3b412e111006ed5a5`	Rebuilt (L-8, I-11, I-13). **Not yet deployed to mainnet.** Supersedes the earlier build (`698b499a…`).
`program/aretia-pool/artifacts/aretia_pool.so`	`ff97a2fdf5663d4fbc5c9fef0341f38905bcd77235afadfd98844020f71ed1a2`	Devnet upgrade pending
`program/aretia-curve-grad/artifacts/aretia_curve_grad.so`	`4eb16715f2410e7de5ac61c15a4b4d634ce39f48f37ad93647070b5373161421`	Devnet upgrade pending

Artifact	sha-256	Status
`program/act-staking/artifacts/act_staking.so`	`1239b9391eb8406ffecbb2bb1e32c2be64e7289fe894f3fb9781d8ad4ede987b`	Built with no features; for a fresh mainnet deploy
`contracts-evm/AretiaCurveRescue` (runtime)	`2035a510b035a908ed1ec558676b1b262465c3456498997e3c34d9172b568d1e`	New; deploy on Ethereum, BNB Chain, Polygon
`contracts-evm/AretiaPairSeeder` (runtime)	`e65f98ae048c927a6e585cd406ad9c2d2f468fa12acd1655e0ed515c892a9b43`	New; deploy per chain
`contracts-evm/AretiaPool` (runtime)	`2a7e4a02250bdf1145397ccd6d10cadc728883c0e7b72a48fbd8175bfd6cfba3`	New build; redeploy on Sepolia, then mainnets when ready

The EVM runtime hashes are compiled with immutables zeroed. `AretiaCurve.sol` and `AretiaTokenFactory.sol` and their artifacts are unchanged.

---

6. Deployment checklist, in order

A. Database (Supabase SQL Editor)

1. Back up the referral table: `create table referral_credits_pre0013 as select * from referral_credits;`
2. Run `website/supabase/migrations/0014_auth_nonces_and_pruning.sql`. It must go in **before the code**; without it sign-in and every signed-in feature fail.
3. Run `0013_referral_tx_case.sql`.
4. Run `0015_launchbox_listing.sql`.

All three are safe to run twice.

B. Vercel environment variables (Production, Sensitive)

1. Set `SWINGS_SESSION_SECRET` to a long random value. Generate it with `openssl rand -hex 32`, or have a password manager create a 64-character random string. Expect everyone to be signed out once.
2. Set `SWINGS_LOGIN_DOMAINS` to `aretiafinance.org,www.aretiafinance.org`.
3. Leave `SWINGS_AGGREGATORS=off` for now.

C. Merge and deploy

1. Open a PR from `claude/eloquent-turing-97mg6r` to `main`, merge it, and let Vercel deploy.
2. Check:
    - you can sign in with an EVM wallet and a Solana wallet;
    - a buy through MoonPay asks you to sign in;
    - Launch Box loads.

D. Turn 0x and Jupiter back on

1. Delete `SWINGS_AGGREGATORS` in Vercel and redeploy.
2. Try one small Solana memecoin swap (Jupiter).
3. Try one small ETH→token and one token→ETH swap (0x).

E. GitHub

1. Move `ETHEREUM_RPC_URL`, `BNB_RPC_URL` and `POLYGON_RPC_URL` from repository variables to secrets, if they are set.
2. Make sure you are notified of issues labelled `security`.

The fee-key monitor starts running once the branch is on `main`.

F. EVM contracts (from your own wallet; nothing deploys automatically)

1. Deploy `AretiaCurveRescue(curve = 0x4e85bc5bd6f08fa87ceb749372e34226556837e8)` on Ethereum, BNB Chain and Polygon.
2. Deploy `AretiaPairSeeder(router)` on each chain.
3. Verify both on the explorers (see `contracts-evm/VERIFY.md` and `docs/BONDING_CURVE_EVM.md` §16).
4. Send the addresses, so they can be written into the site.
5. Redeploy `AretiaPool` on Sepolia when you want the EVM pool card back on.

G. Solana

1. **Before the mainnet curve deploy**, re-run the curve test suite on your machine with Meteora's binary, as you did before. The binary changed (`0275bb1f…`) and its Meteora tests could not run here.
2. Then deploy with the steps given earlier (`curve-solana-mainnet.mjs prepare`, then `verify`). Deploy rent is about 2.75 SOL.
3. **Devnet upgrades:** pool first (`solana program extend` if needed), then curve-grad, then the devnet curve.
4. **act-staking on mainnet:** deploy the committed artifact and call `initialize_config` in the same sitting, signed by the upgrade authority. Verify, then hand config authority to the multisig.

H. Keys Keep the EVM fee key (`0xeb8725…0945`) offline. Never sign an EIP-7702 or "upgrade to smart account" request with it. Never close the Solana fee wallet's wrapped-SOL account.

---

7. Method

Fix phase: six engineers worked on isolated git worktrees, one per area, each adding regression tests that turn the proofs of concept into failing attacks. Each branch was merged with conflicts resolved by hand, and the full suite was re-run after every merge.

Re-audit phase: four independent reviewers (swap and cross-chain; server and database; markets and Launch Box; contracts and programs) each:

- read every diff since `73386ef`;
- wrote their own bypass tests;

- ran migrations on a real Postgres engine (PGlite), including concurrent-nonce races;
- recompiled every EVM artifact and rebuilt every Solana program from a clean copy;
- fuzz-tested `AretiaPool` invariants and differentially fuzzed the mint rule against the on-chain one.

Second round: every material issue the re-audit raised was fixed. The full suite and the original proofs of concept were then run once more.

Tooling: solc-js 0.8.26 · `@ethereumjs/vm` with real Uniswap V2 · Agave `cargo-build-sbf` 2.1.21 · LiteSVM · vitest · PGlite.